

VirtuEx 시스템 감사 보고서 (11차)

프로젝트: VirtuEx - 가상 자산 모의 거래 플랫폼 차수: 11차 감사 (전체 시스템 종합 정기 감사) 작성일: 2026-03-10 작성: 시스템 감사팀

1. 개요

11차 감사는 VirtuEx 프로젝트의 전체 시스템 종합 정기 감사입니다. 10차 감사(2026-03-09) 이후 구현된 실시간 가격 업데이트 파이프라인 수정, 슬롯머신 숫자 애니메이션, 리더보드 PII 마스킹/팔로우 연동 수정 등 신규 변경 사항을 검증하고, 백엔드 8개 마이크로서비스와 프론트엔드 전반에 대한 보안/성능/품질 심층 분석을 수행합니다.

1.1 감사 범위

영역	검사 항목	신규 이슈
보안 — 인증/인가	x-user-role 헤더 신뢰, JWT 토큰 저장, 비밀번호 정책	4건
보안 — 입력 검증	WebSocket 채널명, 파일 업로드, RRN 응답 노출	3건
데이터 무결성	카피 트레이딩 먹등성 키, 주문 취소 비원자성, 조회수 중복	3건
성능	리더보드 전체 로드, base64 이미지, 다중 폴링	3건
구성/암호화	CORS 설정, JWT_SECRET 재사용, Redis 비밀번호	3건
프론트엔드 UX/품질	alert() 사용, 에러 바운더리 하드코딩, timeAgo 중복	4건
접근성	댓글 입력 레이블, 모달 포커스 트랩, 아이콘 버튼	3건
i18n	에러 바운더리, 카테고리 인라인, RichEditor 하드코딩	3건
10차 미수정 잔존	10차 감사 미수정 항목 중 잔존 확인	6건
합계		32건

1.2 심각도 분류

심각도	건수
상 (Critical)	2
중 (Medium)	18
하 (Low)	12
합계	32

2. 10차 감사 수정 현황

10차 감사에서 발견된 30건 중 수정 현황을 검증합니다. (10차 보고서 시점 이미 수정 완료 표기 2건 제외, 실 미수정 28건 대상)

2.1 수정 완료 (12건)

10차 #	항목	수정 내용
#2	카피 트레이딩 잔고 경합 조건	\$transaction + FOR UPDATE 락 적용으로 원자적 잔고 확인/차감 보장
#5	카피 실행 실패 알림 부재	logger.warn() 구조화 로깅 추가, 실패 상세 기록
#6	비활성화 시 미체결 카피 주문	PENDING 상태 실행 건을 CANCELLED로 일괄 변경
#8	슬리피지 보호 미구현	SLIPPAGE_TOLERANCE = 0.02 상수 + 보호 로직 추가
#9	카피 트레이더 수 무제한	팔로워당 최대 10개 활성 카피 설정 제한
#12	자기 팔로우 서버 검증	FollowService.follow()에 followerId === followeeId 검사 확인
#13	활동 피드 민감 정보 노출	정확한 수량/가격 제거, "매수 체결" 등 심볼만 표시
#15	전략 작성 제한 서버 재검증	서버 측 가드로 가입 1일 이상 + 실적 조건 재검증
#16	MEMBERS_ONLY 비인증 접근	직접 URL 접근 시 로그인 모달 표시
#20	활동 피드 빈 상태 UX	트레이더 팔로우 제안 + /community?tab=traders 링크 추가
#23	카피 트레이딩 i18n 누락	copyTrade.side, copyTrade.status, copyTrade.trader 등 7개 키 추가
#28	팔로우 옵티미스틱 UI	onMutate + onError 콜백 패턴 적용

10차 감사 수정률: 12/28건 (42.9%)

2.2 미수정 잔존 (16건)

10차 #	항목	상태	11차 재분류
#1	scaleRatio 범위 검증	미수정	11차 #27로 이관
#4	stopLossPercent 범위 검증	미수정	11차 #27에 통합
#7	원본 주문 참조 무결성	미수정	11차 #28로 이관
#10	활동 피드 N+1 쿼리	미수정	11차 #29로 이관
#11	팔로우 수 실시간 불일치	부분 해결	옵티미스틱 UI로 체감 개선, 캐시 동기화 잔존
#14	visibility 기본값	미수정	11차 #30으로 이관
#17	알림 폴링→WebSocket	미수정	11차 #31로 이관
#18	로그인 모달 포커스 트랩	미수정	11차 접근성 영역에 통합
#19	카피 트레이딩 UI 프리셋	미수정	하 유지
#22	디버그 console.log 잔존	미확인	하 유지
#24	상대 시간 로케일	미수정	11차 i18n 영역에 통합

#25	trader_follows 복합 유니크	미수정	11차 #30에 통합
#26	활동 로그 보존 정책	미수정	하 유지
#27	copy_trade_executions 인덱스	미수정	하 유지
#29	카피 이력 정렬/필터	미수정	하 유지
#30	피드 가상 스크롤	미수정	하 유지

3. 최근 변경 사항 검증

10차 감사 이후 구현된 주요 변경 사항을 검증합니다.

3.1 실시간 가격 업데이트 파이프라인 수정

항목	상태	비고
Redis PSUBSCRIBE 패턴 구독	✅ 수정 완료	20개 하드코딩 → prices:* 전체 구독
WebSocket 데이터 구조 매핑	✅ 수정 완료	raw.data 언래핑 + 필드명 매핑
1초 간격 실시간 전달 검증	✅ 확인	market-data @Interval(1000) → Redis → WebSocket → UI

3.2 AnimatedNumber 슬롯머신 컴포넌트

항목	상태	비고
숫자 자릿수별 슬라이드 애니메이션	✅ 구현	350ms cubic-bezier 전환
방향 감지 (증가=위, 감소=아래)	✅ 구현	숫자 파싱 비교 기반
비숫자 문자(콤마, 점, 통화기호) 처리	✅ 구현	애니메이션 없이 정적 렌더
적용 범위	✅ 확인	PriceDisplay, BalanceCard, MarketTicker, AssetListItem
CSS 키프레임	✅ 확인	globals.css에 4개 애니메이션 정의

3.3 리더보드 PII 마스킹 + 팔로우 연동 수정

항목	이전	수정 후
타인 userId	anon_N (UUID 무효)	인증 시 실제 UUID 제공, 비인증 시 anon_N 유지
팔로우 API 호출	Prisma UUID 파싱 에러 500	정상 동작
배치 카운트 조회	anon_ID 포함 요청	anon_ 접두사 필터링

3.4 기타 수정

항목	상태
----	----

TipTap SSR 하이드레이션 에러	✅ <code>immediatelyRender: false</code> 적용
페이지뷰 통계 429 에러	✅ 레이트 리밋 100회/60초로 완화
ESLint 미사용 변수 (locale)	✅ 제거

4. 상 (Critical) — 2건

#1. 커뮤니티 컨트롤러 x-user-role 헤더 신뢰 — 권한 상승 위험

- 심각도: 상
- 영역: 백엔드 보안 — 인가 우회
- 파일: `backend/services/user-auth/src/presentation/controllers/community.controller.ts` (267행, 389행, 509행)
- 설명: `deletePost`, `deleteComment`, `deleteAttachment` 메서드에서 `@Headers('x-user-role')` `userRole` 을 직접 읽어 관리자 권한을 부여합니다. `InternalAuthGuard` 는 `x-internal-token` 만 검증하고 JWT 페이로드를 확인하지 않으므로, API Gateway 프록시 컨트롤러에서 이 헤더를 JWT에서 추출한 값으로 명시적 덮어쓰기하는지 여부가 보안의 핵심입니다. 클라이언트가 직접 `x-user-role: ADMIN` 헤더를 전송할 경우 권한 상승이 가능합니다.
- 권장 수정: 커뮤니티 프록시 컨트롤러에서 `x-user-role` 을 반드시 JWT 인증된 사용자의 `role` 로 덮어쓰기. 또는 `user-auth` 서비스 내에서 `userId`로 DB 조회하여 `role` 확인

#2. 카피 트레이딩 복제 주문 시 멍등성 키(idempotencyKey) 누락

- 심각도: 상
- 영역: 데이터 무결성 — 카피 트레이딩
- 파일: `backend/services/portfolio/src/domain/services/copy-trade.service.ts` (372–388행)
- 설명: `processCopyTrade` 에서 `order-engine`으로 주문을 전송할 때 `idempotencyKey` 를 포함하지 않습니다. `PlaceOrderRequestDto` 는 `@IsString()` `@NotEmpty()` 로 멍등성 키를 필수 필드로 요구합니다. 일시적 네트워크 오류 후 재시도 시 동일 원본 거래에 대해 중복 카피 주문이 생성될 수 있습니다.
- 권장 수정: 결정적 멍등성 키 생성: `copyTrade:${config.id}:${tradeData.tradeId}` 형식으로 주문 페이로드에 포함

5. 중 (Medium) — 18건

5.1 보안 — 인증/인가 (4건)

#	항목	설명
#3	JWT 토큰 sessionStorage 저장	<code>stores/auth.ts</code> 에서 <code>accessToken</code> 을 <code>sessionStorage</code> 에 저장. XSS 취약점 발생 시 토큰 탈취 가능. <code>refreshToken</code> 은 이미 <code>httpOnly</code> 쿠키 사용 중이므로 <code>accessToken</code> 도 동일 패턴 적용 권장
#4	비밀번호 재설정 시 약한 검증	<code>auth.service.ts:575</code> / <code>forgot-password/page.tsx:158</code> — 재설정 시 <code>length < 8</code> 만 확인. 회원가입 시 요구하는 소문자+숫자+특수문자 정책 미적용. 약한 비밀번호 설정 가능
#5	프로필 수정 시 전화번호 재인증 미요구	<code>mypage/edit/page.tsx:126</code> — 회원가입 시 SMS 인증 필수이나, 프로필 수정에서 전화번호 변경 시 재인증 없이 저장 가능

#6	Next.js 미들웨어 서버 측 인증 미검증	middleware.ts:4-13 — 관리자/보호 라우트에서 헤더만 설정하고 서버 측 토큰 검증 없음. 인증 전 페이지 번들이 다운로드됨
----	--------------------------	--

5.2 보안 — 입력 검증/정보 노출 (3건)

#	항목	설명
#7	WebSocket subscribe 채널명 미검증	price.gateway.ts:109-137 — data.channel과 data.symbols에 대한 형식/길이 검증 없음. 악의적 클라이언트가 내부 채널 구독 또는 거대 문자열 전송 가능
#8	RRN 검증 오류 상세 노출	auth.service.ts:96-98 — Invalid resident number: \${rrnValidation.message}로 구체적 검증 실패 사유 반환. 공격자의 유효 RRN 추측 시도 지원
#9	Base64 이미지 서버 측 미검증	RichEditor.tsx:99-104 — 클라이언트에서 MIME/크기 검증하지만, 서버 측 재검증 없어 직접 API 호출로 우회 가능. 악성 콘텐츠 DB 저장 위험

5.3 데이터 무결성/성능 (3건)

#	항목	설명
#10	주문 취소 비원 자적 처리	order.service.ts:267-351 — 이벤트 스토어 CANCEL 커밋 후 읽기 모델 업데이트 및 자금 반환 수행. 중간 실패 시 이벤트-읽기 모델 불일치 발생
#11	커뮤니티 조회수 중복 카운트	community.controller.ts:326-339 — POST .../view 요청마다 +1 증가. 사용자/IP 별 중복 방지 없어 조회수 인위적 부풀리기 가능
#12	커뮤니티 파일 업로드 제한 부재	community.controller.ts:451-503 — 10MB/건 제한만 존재. 게시글당/사용자당/시간당 첨부 수 제한 없어 디스크 공간 고갈 가능

5.4 구성/암호화 (3건)

#	항목	설명
#13	API Gateway CORS 단일 문자열 처리	api-gateway/src/main.ts:92 — CORS_ORIGIN 환경변수를 쉼표 분리 없이 단일 문자열로 전달. WebSocket 게이트웨이는 .split(',') 처리하지만 HTTP CORS는 미처리. 다중 오리진 시 전체 차단
#14	JWT_SECRET을 RRN 암호화 키로 재사용	auth.service.ts:100 — JWT 서명 키와 주민번호 AES 암호화 키가 동일. JWT_SECRET 노출 시 전체 주민번호 복호화 가능
#15	PriceSubscriber Redis 비밀번호 미처리	price-subscriber.service.ts:51-52 — new Redis(redisUrl) 직접 생성. PriceCacheService와 달리 REDIS_PASSWORD 별도 처리 없음

5.5 프론트엔드 UX/품질 (5건)

#	항목	설명
---	----	----

#16	alert() 사용 — 접근성/UX 위반	RichEditor.tsx:90,95, community/[id]/page.tsx:265, community/new/page.tsx:131,137 등 — 메인 스크린 차단. 앱 전체에서 toast 시스템 사용 중이나 일부 alert() 잔존
#17	에러 바운더리 한국어 하드코딩	8개 에러 페이지에서 '일시적인 오류가 발생했습니다.' 하드코딩. useTranslation() 미사용
#18	timeAgo 유틸리티 5곳 중복 구현	community/[id]/page.tsx, strategy/[id]/page.tsx, ActivityFeed.tsx, NotificationBell.tsx, RoomList.tsx — 동일 로직 5회 복사. 한/영 문자열 하드코딩
#19	SMS 인증코드 부분 로깅	sms-verification.service.ts:40-44 — 프로덕션에서 코드 끝 2자리 ****XX 로깅. 로그 접근자가 4자리만 브루트포스하면 6자리 코드 해독 가능
#20	\$queryRawUnsafe 사용	copy-trade.service.ts:312 — 매개변수화 사용 중이나 메서드명이 안전하지 않은 경로. 향후 수정 시 직접 문자열 삽입 위험. \$queryRaw 태그드 템플릿 리터럴로 전환 권장

6. 하 (Low) — 12건

#	영역	항목	설명
#21	접근성	댓글 입력 aria-label 누락	community/[id]/page.tsx:419-424 — <input>에 placeholder만 존재, aria-label 없음
#22	접근성	프로필 수정 확인 모달 포커스 트랩	mypage/edit/page.tsx:178-208 — 자체 모달 구현으로 ConfirmModal 컴포넌트 미사용. 포커스 트랩 미적용
#23	접근성	댓글 삭제/좋아요 아이콘 버튼 aria-label	community/[id]/page.tsx:117-122 — 아이콘만 표시, 스크린리더 접근 불가
#24	i18n	RichEditor alert() 인라인 한/영	RichEditor.tsx:90,95 — alert('이미지 크기는...\nImage size...') 하드코딩
#25	i18n	커뮤니티 카테고리 인라인 ko/en	community/new/page.tsx:24-31 등 — { ko: '자유토론', en: 'Discussion' } 인라인 정의
#26	성능	다중 폴링 인터벌 배경 부하	useOrders.ts 5초, usePortfolio.ts 10초, useMarket.ts 30초, useAdmin.ts 30초 — 다중 탭 시 트래픽 배증. visibilitychange 기반 전환 권장
#27	10차 잔존	scaleRatio/stopLossPercent DTO 범위 검증	10차 #1, #4 통합. 카피 트레이딩 설정 값 서버 측 범위 미제한
#28	10차 잔존	원본 주문 참조 무결성	10차 #7. 원본 주문 삭제/취소 시 카피 실행 레코드 참조 정합성
#29	10차 잔존	활동 피드 N+1 쿼리	10차 #10. 팔로우 트레이더 다수 시 피드 조회 성능
#30	10차 잔존	visibility 기본값 + 유니크 인덱스	10차 #14, #25 통합. community_posts 기본값 및 trader_follows 복합 유니크 확인 필요

#31	10차 잔존	알림 폴링→WebSocket 전환	10차 #17. NotificationBell 폴링 방식 잔존
#32	코드 품질	catch (error: any) 타입 미지정	다수 파일에서 catch (error: any) 사용. catch (error: unknown) + instanceof Error 타입 가드 권장

7. 리더보드 전체 계정 메모리 로드 (성능 특별 주의)

`balance.service.ts:804` 에서 `this.prisma.account.findMany()` 가 **제한 없이 전체 계정**을 메모리에 로드합니다. 현재 소규모 사용자 기반에서는 문제없으나, 사용자 증가 시 OOM(Out of Memory) 위험이 있습니다. 보유 자산, 거래 집계도 전체 사용자 대상으로 로드합니다.

- 현재 심각도: 하 (소규모 운영)
- 잠재 심각도: 상 (사용자 증가 시)
- 권장: 주기적으로 갱신되는 리더보드 캐시 테이블 또는 Redis 캐시 도입

8. 긍정적 평가 사항

8.1 10차 이후 개선 사항

- 실시간 가격 파이프라인 정상화: Redis PSUBSCRIBE + WebSocket 데이터 매핑 수정으로 전 종목 1초 간격 실시간 가격 업데이트 달성
- **AnimatedNumber** 컴포넌트: 슬롯머신 스타일 숫자 전환 애니메이션으로 가격 변동 시각적 피드백 대폭 향상
- 리더보드 PII 마스킹 + 팔로우 연동: 비인증 시 UUID 익명화, 인증 시 실제 ID 제공으로 보안과 기능성 양립
- 카피 트레이딩 안전장치 대거 보강: 경합 조건 해결(FOR UPDATE), 슬리피지 보호, 트레이더 수 제한, 미체결 주문 일괄 취소 등 10차 Critical 이슈 해결

8.2 기존 우수 사항 유지

- **InternalAuthGuard**: `timingSafeEqual` 상수 시간 비교로 타이밍 공격 방어
- **Refresh Token**: SHA-256 해시 저장 + httpOnly secure 쿠키 + SameSite
- 입력 검증: `class-validator` DTO + `whitelist / forbidNonWhitelisted` 전역 적용
- 전역 예외 필터: 스택 트레이스 제거, 내부 정보 미노출
- **AES-256-GCM**: 레코드별 salt로 주민번호 암호화
- 이중 언어 주석: 한/영 JSDoc 표준 유지

9. 최우선 조치 권장 순서

순위	#	항목	이유
1	#1	x-user-role 헤더 신뢰	관리자 권한 상승으로 게시글/댓글/첨부파일 무단 삭제 가능
2	#2	카피 트레이딩 역등성 키	재시도 시 중복 주문 생성 → 자산 오류
3	#4	비밀번호 재설정 약한 검증	회원가입 대비 낮은 비밀번호 정책으로 계정 보안 약화
4	#14	JWT_SECRET RRN 재사용	키 노출 시 전체 주민번호 복호화 가능
5	#7	WebSocket 채널명 미검증	내부 채널 구독/DoS 공격 벡터
6	#13	CORS 다중 오리진 미처리	프로덕션 배포 시 프론트엔드 요청 전면 차단 가능

7	#10	주문 취소 비원자성	이벤트 스토어-읽기 모델 불일치
---	-----	------------	-------------------

10. 이전 감사 대비 추이

차수	상	중	하	합계	비고
6차	8	32	35	75	최초 종합 감사
7차	5	29	28	62	6차 47건 수정 확인
8차	6	24	12	42	UX 벤치마킹 포함
9차	4	26	18	48	채팅/커뮤니티 신규 기능
10차	3	17	10	30	소셜/카피 트레이딩
11차	2	18	12	32	전체 종합 정기 감사

Critical 이슈가 3건에서 2건으로 감소한 것은 10차 카피 트레이딩 Critical 3건 중 경합 조건(#2)이 수정된 성과입니다. 11차 Critical은 권한 상승과 멍등성이라는 새로운 영역의 이슈로, 기존 금융 로직 안전성은 개선되었습니다.

11. 종합 평가

11.1 영역별 성숙도 (10차 대비)

항목	10차	11차	변화	비고
인증/인가	4.0/5	3.5/5	▼-0.5	x-user-role 헤더 신뢰 이슈 발견
입력 검증	4.0/5	4.0/5	—	WebSocket 채널 검증 필요, DTO 검증은 양호
데이터 무결성	3.5/5	4.0/5	▲+0.5	카피 트레이딩 FOR UPDATE + 슬리피지 수정
실시간 기능	3.0/5	4.5/5	▲+1.5	가격 파이프라인 정상화 + AnimatedNumber
프론트엔드 UX	4.0/5	4.0/5	—	애니메이션 개선, alert() 잔존으로 상쇄
프론트엔드 코드 품질	4.5/5	4.0/5	▼-0.5	timeAgo 중복, any 타입 잔존
i18n	4.0/5	3.5/5	▼-0.5	에러 바운더리/카테고리 하드코딩 발견
DB 설계	3.5/5	3.5/5	—	10차 인덱스/정책 이슈 잔존
암호화/구성	4.0/5	3.5/5	▼-0.5	JWT_SECRET 재사용, Redis 비밀번호
종합	3.9/5	3.8/5	▼-0.1	

11.2 누적 감사 현황

차수	유형	발견	수정	스킵	미수정
1차	신규 감사	36	36	0	0
2차	신규 감사	50	45	4	1

3차	수정 검증	0	—	—	—
4차	신규 감사	79	79	0	0
5차	수정 검증	0	—	—	—
6차	종합 심층 감사	75	47	0	28
7차	종합 정기 감사	62	57	5	0
8차	종합 감사 + UX 벤치마킹	42	42	0	0
9차	종합 정기 감사	48	48	0	0
10차	소셜/UX 기능 감사	30	12	0	18
11차	전체 종합 정기 감사	32	미수정	0	32
누적		454	366	9	79

11.3 결론

11차 감사는 VirtuEx의 **전체 시스템 종합 정기 감사**로, 백엔드 8개 마이크로서비스와 프론트엔드 전반을 대상으로 수행되었습니다.

핵심 성과:

- **실시간 가격 파이프라인 정상화**: Redis PSUBSCRIBE + WebSocket 데이터 매핑 수정으로 전 종목 1초 간격 실시간 가격 업데이트 달성. 실시간 기능 성숙도가 3.0에서 **4.5로 대폭 상승**
- **카피 트레이딩 안전성 대거 개선**: 10차 Critical 3건 중 경합 조건, 슬리피지, 트레이더 수 제한 등 핵심 이슈 해결. 데이터 무결성 성숙도 3.5에서 **4.0으로 상승**

핵심 조치 사항:

1. **권한 상승 방지 (상 #1)**: x-user-role 헤더를 JWT 인증 값으로 강제 덮어쓰기. 커뮤니티 관리 기능의 보안 기반
2. **카피 트레이딩 먹등성 (상 #2)**: 결정적 먹등성 키로 재시도 안전성 확보. 자산 오류 예방
3. **비밀번호 정책 통일 (중 #4)**: 회원가입과 재설정의 비밀번호 복잡도 요구사항 일치
4. **암호화 키 분리 (중 #14)**: JWT_SECRET과 RRN 암호화 키를 분리하여 키 노출 시 피해 범위 제한

종합 성숙도는 실시간 기능 대폭 개선에도 불구하고 새로운 보안 이슈 발견으로 3.9에서 **3.8로 소폭 하락**했습니다. 권한 상승(#1)과 암호화 키 재사용(#14) 해결 후 **4.0 이상 달성**이 가능할 것으로 평가됩니다.